Process Mining appliqué au SOC – Rapport d'audit (Mini-projet 1, CITECH)

Oct 31, 2026 · @ANAS

1. Introduction et contexte du SOC

L'audit de 821 événements d'authentification (140 incidents) montre que le SOC suit bien son processus de réponse dans 73 cas sur 140, mais qu'il s'en écarte de façon risquée dans 10 incidents d'attaque, dont 9 clôturés sans aucune investigation de l'adresse IP source.

1.1 Contexte

La compromission de comptes est l'un des vecteurs d'intrusion les plus fréquents dans le secteur des services financiers : un identifiant valide permet à l'attaquant de contourner les contrôles périmétriques, de se fondre dans le trafic légitime et d'atteindre des données sensibles (comptes clients, ordres de paiement, données RH). Le Security Operations Center (SOC) de l'entreprise supervise les journaux d'authentification, génère des alertes via le SIEM et applique un processus de réponse à incident normalisé : détection, qualification (triage), investigation de l'IP source, confinement (blocage de l'IP, désactivation du compte), remédiation (réinitialisation du mot de passe) puis clôture.

Le processus de référence est strictement séquentiel : `Multiple_Login_Failures → SIEM_Alert_Created → SOC_Triage → IP_Investigated → IP_Blocked → Account_Disabled → Password_Reset → Incident_Closed`. La question de ce rapport est de savoir si la pratique réelle correspond à ce modèle, où elle s'en écarte, et si ces écarts relèvent de la simple variation opérationnelle ou d'un risque de sécurité.

1.2 Problématique et objectifs

Le Process Mining apporte une réponse factuelle : plutôt que de se fier aux procédures écrites ou aux déclarations des analystes, il reconstruit le processus réel à partir des traces horodatées laissées dans les systèmes. Ce rapport poursuit quatre objectifs :

1. Découvrir le comportement réel du SOC (modèle AS-IS) et le comparer au modèle de référence.

2. Mesurer la performance : délais de transition, durée de cycle, goulots d'étranglement, effet du retraitement.
3. Qualifier les déviations du point de vue de la cybersécurité (risque réel ou variation sans conséquence).
4. Proposer un processus cible (TO-BE) assorti de recommandations mesurables par des KPI et des SLA.

1.3 Périmètre et plan

Le journal couvre 11 activités et 4 scénarios : `Benign` (57 cas), `BruteForce` (35), `CredentialStuffing` (31) et `CompromisedAccount` (17). Les 83 cas d'attaque sont les seuls à relever du processus de réponse à incident ; les 57 cas bénins servent de témoin. Le rapport suit la démarche suivante : préparation des données (section 2), modélisation et conformité (section 3), performance (section 4), analyse des déviations en cybersécurité (section 5), processus TO-BE et recommandations (section 6), ouverture vers l'IA prédictive (section 7), puis conclusion (section 8).

[Insérer ici le schéma du contexte : sources de logs → SIEM → SOC → IAM]

2. Méthodologie : préparation des données et journal XES

Le journal d'événements a été audité puis converti au format XES avec une seule correction de données : une valeur `resource` manquante a été remplacée par `Unknown_System`. Le jeu final contient 821 événements, 140 cas, 11 activités et 5 variantes.

2.1 Mapping vers le standard XES

Concept Process Mining	Attribut du journal	Rôle
Identifiant de cas	`incident_id` (AUTH-0001 à AUTH-0140)	Regroupe les événements d'un même incident
Activité	`concept:name`	Etape du processus
Horodatage	`time:timestamp`	Ordre et délais
Ressource	`org:resource`	Analyste ou système exécutant

Concept Process Mining	Attribut du journal	Rôle
Attributs d'analyse	`source_ip`, `host`, `user_id`, `risk_level`, `scenario_label`, `department`	Segmentation et enrichissement

2.2 Contrôle qualité et traitements appliqués

- **Valeur manquante** : un seul `resource` vide, imputé par `Unknown_System` pour ne pas perdre l'événement.
- **Horodatages** : conversion par `pd.to_datetime(format='mixed', dayfirst=True)`, car le fichier mélange plusieurs formats. Un horodatage de format atypique (cas AUTH-0017) a été identifié ; il concerne un cas bénin et n'affecte aucune conclusion sur les incidents d'attaque.
- **Tri** : les événements sont ordonnés par cas puis par horodatage avant export.
- **Limite connue** : l'attribut `department` varie à l'intérieur d'un même cas (3,44 valeurs distinctes en moyenne). Les comparaisons par département sont donc indicatives et ne servent pas de base à une conclusion.

2.3 Outils et techniques

L'analyse repose sur PM4Py. Les techniques utilisées sont :

1. **Variantes** : regroupement des cas ayant la même séquence d'activités.
2. **DFG (Directly-Follows Graph)** : graphe des transitions observées, en fréquence et en performance.
3. **Inductive Miner** : découverte d'un réseau de Petri (15 places, 20 transitions, 14 arcs DFG), exporté en `MiniProjet1_Discovered_Model.pnml`.
4. **Rejeu de jetons (Token-Based Replay)** : mesure de la fitness et de la précision du journal contre le modèle de référence.
5. **Analyse de performance** : délais entre activités, durée de cycle par cas, détection du retraitement (`has_rework` : nombre d'événements supérieur au nombre d'activités distinctes).

[Insérer ici la capture du notebook ou du pipeline de préparation des données]

3. Modélisation théorique et réalité opérationnelle

Le comportement dominant du SOC est conforme au modèle de référence : la variante 1 regroupe 73 des 140 cas, soit 52,1 % du journal. Mais 47,9 % des cas ne suivent pas ce chemin, et il faut distinguer les cas bénins, hors périmètre, des vraies déviations.

3.1 Modèle AS-IS théorique (BPMN)

Le modèle de référence est un réseau de Petri purement séquentiel (9 places, 8 transitions, 16 arcs). En BPMN, on le représente avec deux couloirs : le **SOC** (détection, triage, investigation, blocage, clôture) et l'**IAM** (désactivation du compte, réinitialisation du mot de passe). Il ne comporte ni passerelle de décision, ni boucle, ni raccourci : chaque incident doit traverser les huit activités dans l'ordre.

[Insérer ici la capture du BPMN AS-IS]

3.2 Process Discovery : comportement réel (Q1 et Q2)

Cinq variantes ont été observées. La variante 1 (73 cas) est le comportement dominant :

`Multiple_Login_Failures → SIEM_Alert_Created → SOC_Triage → IP_Investigated → IP_Blocked → Account_Disabled → Password_Reset → Incident_Closed`

Les variantes secondaires se répartissent ainsi : la variante 2 correspond au processus bénin (`Login_Failed → Login_Success → Session_Closed` , 57 cas) ; les variantes 3, 4 et 5 sont des déviations du processus d'incident (respectivement 5, 4 et 1 cas).

Le modèle découvert par l'Inductive Miner met en évidence ces écarts par des transitions silencieuses :

- une branche exclusive entre le chemin bénin et le chemin d'incident ;
- `skip_12` : saut de `IP_Investigated` ;
- `skip_11` : saut de `IP_Investigated` et de `IP_Blocked` ;
- `skip_13` : saut de `Password_Reset` ;
- `skip_9` : retour vers `SOC_Triage` , c'est-à-dire un retraitement ;
- `skip_5` : retour vers `SIEM_Alert_Created` .

Ces boucles et raccourcis n'existent pas dans le modèle de référence : le processus réel est donc plus permissif que le processus prévu, ce qui est précisément le risque à évaluer.

[Insérer ici la capture du DFG de fréquence]

[Insérer ici la capture du réseau de Petri découvert (Inductive Miner)]

3.3 Conformance Checking

Le rejeu de jetons du journal sur le modèle de référence donne :

Indicateur	Valeur	Lecture
Fitness globale du journal	90,38 %	Part des événements que le modèle sait rejouer
Traces parfaitement conformes	52,14 % (73 cas)	Exactement la variante 1
Fitness moyenne par trace	0,5739	Tirée vers le bas par les cas bénins
Précision	85,64 %	Le modèle n'autorise que peu de comportements non observés

Une lecture naïve conclurait que 47,86 % des incidents sont non conformes. La décomposition est plus nuancée :

- **57 cas bénins (40,7 % du journal)** sont hors périmètre du modèle de réponse à incident ; leur non-conformité est mécaniquement attendue.
- **10 cas d'incident déviants** (variantes 3, 4 et 5), soit 7,1 % du journal et 12,0 % des 83 cas d'attaque.
- Le taux de conformité réel du SOC sur les attaques est donc de **87,95 %** (73 sur 83).

Ces 12 % sont l'objet de la section 5 : ils ne sont pas des anomalies statistiques, mais des contrôles de sécurité qui ont été sautés ou répétés.

[Insérer ici la capture du résultat de conformité (fitness / précision)]

4. Analyse de la performance et goulots d'étranglement

Le délai de réponse est homogène et structurel : chaque transition d'un incident d'attaque prend environ 10 à 11 minutes, quel que soit l'analyste. Le goulot le plus fiable est la détection → triage (11,1 min en moyenne sur 83 cas), et les durées les plus longues concernent les attaques par force brute et les comptes compromis.

4.1 Goulot d'étranglement (Q5 complémentaire)

Transition	Délai moyen (min)	Cas concernés	Lecture
`SOC_Triage` → `Account_Disabled`	11,4	5	Le plus élevé, mais sur un échantillon très réduit
`SIEM_Alert_Created` → `SOC_Triage`	11,1	83	Goulot statistiquement robuste

La première valeur est la plus élevée du graphe de performance, mais elle ne repose que sur les 5 cas qui sautent l'investigation et le blocage de l'IP. Nous retenons donc comme goulot principal l'attente entre l'alerte SIEM et la prise en charge par un analyste : elle porte sur la totalité des 83 cas d'attaque. Le délai moyen par analyste varie seulement de 10,8 à 11,4 minutes : le retard ne vient pas d'un opérateur lent, mais de l'organisation (file d'attente manuelle, absence de priorisation automatique).

[Insérer ici la capture du DFG de performance]

4.2 Durée de cycle et incidents les plus longs (Q4)

Les trois incidents les plus longs sont tous des attaques :

Incident	Durée (min)	Scénario
AUTH-0042	106	BruteForce
AUTH-0113	103	CredentialStuffing
AUTH-0112	98	CredentialStuffing

Par type d'incident, le **BruteForce (74,8 min)** et le **CompromisedAccount (71,7 min)** sont les plus lents. Les cas bénins durent environ 22 minutes et ne sont pas comparables. Le délai du BruteForce est d'autant plus préoccupant que c'est l'attaque dont la fenêtre d'exploitation est la plus courte : l'attaquant enchaîne les essais de mots de passe tant que l'IP n'est pas bloquée.

4.3 Les incidents à risque élevé sont-ils traités plus vite ? (Q5)

Non. La durée moyenne est de **53,6 min pour le risque High contre 50,5 min pour le risque Low** : l'ordre est inverse de celui attendu. Ce résultat contre-intuitif s'explique par deux effets :

1. **Dilution par les cas bénins** : 20 des 57 cas bénins portent un `risk_level` High, ce qui tire la moyenne vers le bas.
2. **Absence de priorisation réelle** : en ne retenant que les attaques, la durée est de 74,2 min (High), 69,3 min (Medium) et 71,5 min (Low). L'écart est faible et ne suit aucune logique de criticité.

Le niveau de risque est donc un champ descriptif, qui ne pilote ni la file de traitement ni le délai de réponse. C'est un défaut d'organisation à corriger (recommandation de priorisation, section 6).

4.4 Effet du retraitement (Q4 complémentaire)

Groupe	Durée moyenne (min)
Sans retraitement	51,09
Avec retraitement	59,60

En apparence, le retraitement allonge le cycle d'environ 8,5 minutes. Cette comparaison est biaisée : le groupe sans retraitement contient les 57 cas bénins (environ 22 min). En se limitant aux attaques, les 5 cas avec retraitement durent 59,6 min contre 72,3 min pour les attaques sans retraitement. Ce résultat s'explique par le fait que 4 de ces 5 cas sautent aussi `IP_Investigated`. Chaque cause a un effet mesurable : un second triage coûte environ 10,75 min, tandis que l'omission de l'investigation fait gagner environ 20,5 min (10,4 + 10,1 min de transitions supprimées).

La conclusion opérationnelle est claire : les cas les plus rapides ne sont pas les mieux traités. Les raccourcis (variante 3 : environ 41 min contre environ 74 min pour la variante 1) gagnent du temps en supprimant des contrôles.

4.5 Problèmes opérationnels identifiés

Problème	Cause	Amélioration	KPI / SLA
Attente de 11 min avant triage	File d'alertes traitée manuellement, sans priorité	Routage automatique par criticité et type d'attaque	MTTT (délai alerte → triage) ⩽ 5 min pour High
Durées égales pour toutes les criticités	`risk_level` non utilisé dans le routage	Priorisation et files séparées	Délai High inférieur au délai Low d'au moins 30 %
Retraitement du triage (4 cas)	Alerte non qualifiée ou doublon	Enrichissement SIEM et déduplication	Taux de re-triage < 2 %

5. Analyse cybersécurité des déviations

Sur les 83 incidents d'attaque, 9 ont été clôturés sans investigation de l'adresse IP et 4 ont subi un triage en double. Les premiers constituent un risque de sécurité avéré ; les seconds sont une inefficacité opérationnelle. Cette distinction guide la priorité des corrections.

5.1 Incidents sans investigation de l'IP (Q3)

Neuf incidents ont été clôturés sans l'activité `IP_Investigated`, par exemple AUTH-0039 et AUTH-0070 (risque High, scénario CredentialStuffing). Ce constat est le plus grave de l'audit, pour quatre raisons :

1. **L'IP est la seule clé de corrélation entre incidents.** Dans le journal, 4 adresses IP externes seulement couvrent l'ensemble des 83 cas d'attaque. Sans investigation, le SOC ne voit pas qu'il traite une même campagne ; chaque cas est vu comme un événement isolé.
2. **Le blocage devient aveugle.** Dans la variante 3, l'IP n'est jamais bloquée : l'attaquant conserve son infrastructure et peut relancer une campagne immédiatement, avec les mêmes identifiants.
3. **Le credential stuffing est une attaque en volume.** Il réutilise des identifiants issus de fuites sur de nombreux comptes. Ne pas vérifier la réputation, la géolocalisation et le nombre de comptes ciblés par l'IP revient à ne traiter qu'un compte sur plusieurs touchés.

4. **La réinitialisation du mot de passe ne suffit pas.** Elle protège un compte, pas les autres comptes attaqués depuis la même source, ni les comptes dont le mot de passe a déjà été validé par l'attaquant avant la détection.

En outre, la clôture sans investigation produit un dossier incomplet : pour un établissement financier, elle affaiblit la traçabilité exigée lors d'un audit réglementaire ou d'une enquête post-incident.

Enfin, ces cas se clôturent plus vite (variante 3 : environ 41 min contre environ 74 min pour la variante 1). Un indicateur de délai seul récompenserait donc le comportement le plus dangereux : il faut associer chaque SLA à un contrôle de conformité.

5.2 Triage en double (Q3)

Quatre incidents présentent deux activités `SOC_Triage`. Cela correspond à la boucle `skip_9` du modèle découvert. Le risque de sécurité est indirect : le second triage ajoute environ 10,75 min avant le confinement. L'effet est faible sur un incident isolé, mais critique si l'on cumule les délais.

5.3 Pourquoi 11 minutes de triage sont critiques en cas de Brute Force

Une attaque par force brute génère un nombre élevé de tentatives par minute, ce que matérialise l'événement `Multiple_Login_Failures`. Tant que le triage n'a pas eu lieu, aucun confinement n'est déclenché :

- Les tentatives se poursuivent ; la probabilité qu'un mot de passe faible soit deviné augmente avec chaque minute d'attente.
- Si l'attaquant réussit pendant cette fenêtre, il dispose d'une session valide avant que le compte soit désactivé. L'incident passe alors de la tentative d'intrusion à la compromission de compte (`CompromisedAccount`), dont la durée moyenne est elle-même élevée (71,7 min).
- Les 11 minutes ne sont que le premier délai : à ces 11 minutes s'ajoutent les autres transitions de 10 à 11 minutes, ce qui porte la durée moyenne du BruteForce à 74,8 minutes avant clôture.

Le délai de triage n'est donc pas un simple indicateur de confort : il définit la fenêtre d'exposition. Un SIEM bien configuré doit pouvoir déclencher un blocage temporaire automatique dès le seuil de tentatives atteint, sans attendre un analyste.

5.4 Comparaison des trois scénarios d'attaque

Scénario	Cas	Durée moyenne (min)	Signature et risque principal
BruteForce	35	74,8	Essais multiples sur un compte ; fenêtre d'exposition courte et critique
CredentialStuffing	31	67,7	Identifiants issus de fuites sur de nombreux comptes ; nécessite la corrélation par IP
CompromisedAccount	17	71,7	Accès déjà obtenu ; risque de mouvement latéral et d'exfiltration

[Insérer ici le graphique de comparaison des durées par scénario]

5.5 Risque de sécurité ou simple variation opérationnelle ? (Q6)

Déviation	Cas	Nature	Justification
Absence de `IP_Investigated`	9	**Risque de sécurité**	Pas de corrélation, de blocage ciblé ni de traçabilité
Absence de `IP_Blocked` (variante 3)	5	**Risque de sécurité**	L'attaquant garde son infrastructure
`Password_Reset` sauté (`skip_13`)	5	**Risque de sécurité**	Identifiant potentiellement compromis toujours valide
Double `SOC_Triage`	4	Variation opérationnelle	Perte de temps, sans perte de contrôle
Chemin bénin (`Login_Failed` → `Session_Closed`)	57	Normal	Hors périmètre de réponse à incident

5.6 Limites de l'analyse

- Seuls 4 adresses IP externes alimentent tous les cas : le jeu est synthétique et ne permet pas de généraliser à un SOC réel.
- Les effectifs des variantes déviantes sont faibles (5, 4 et 1 cas) ; les moyennes associées sont indicatives.

- Le champ `department` n'est pas stable dans un cas ; il n'est pas utilisé comme critère de conclusion.

6. Processus TO-BE et recommandations

Le processus cible rend l'investigation de l'IP obligatoire, automatise les délais de 10 à 11 minutes qui sont structurels, et priorise les incidents selon leur criticité. Il vise à réduire le délai de prise en charge sans autoriser de raccourci.

6.1 Modèle TO-BE (BPMN)

Le BPMN TO-BE conserve les couloirs SOC et IAM et ajoute un couloir **SOAR/SIEM** pour les tâches automatisées :

1. **Détection** : `Multiple_Login_Failures` déclenche une alerte SIEM enrichie (réputation de l'IP, géolocalisation, nombre de comptes ciblés, type de scénario).
2. **Passerelle de priorisation** (exclusive) : selon la criticité et le type d'attaque, l'alerte est dirigée vers la file prioritaire ou standard, avec un SLA différent.
3. **Blocage temporaire automatique** : dès qu'un seuil de tentatives est franchi, le SOAR bloque l'IP et verrouille le compte de façon réversible, avant l'arrivée de l'analyste.
4. **SOC_Triage** unique, avec contrôle de déduplication pour éviter le second triage.
5. **IP_Investigated** obligatoire : la tâche de clôture est verrouillée tant que cette activité n'est pas tracée. L'IP est comparée à une liste de blocage partagée.
6. **IP_Blocked, Account_Disabled, Password_Reset** exécutés en parallèle (IP côté SOC, compte et mot de passe côté IAM) plutôt qu'en séquence.
7. **Incident_Closed** seulement après validation d'une liste de contrôle de conformité.

[Insérer ici la capture du BPMN TO-BE]

6.2 Comparaison AS-IS et TO-BE (Q2 complémentaire)

Dimension	AS-IS	TO-BE
Prise en charge de l'alerte	Manuelle, environ 11 min	File priorisée, 5 min ou moins pour les incidents High
Investigation de l'IP	Sautée dans 9 cas sur 83	Obligatoire, clôture verrouillée

Dimension	AS-IS	TO-BE
Blocage de l'IP	Manuel, répété cas par cas (4 IP pour 83 cas)	Automatique, liste de blocage partagée
Etapes de remédiation	Séquentielles	Parallèles entre SOC et IAM
Priorisation	Aucune effective (High 74,2 min, Low 71,5 min)	Par criticité et type d'attaque
Triage	Doublon dans 4 cas	Unique, avec déduplication
Clôture	Libre	Conditionnée à une liste de contrôle

6.3 Cinq recommandations

1. **Automatisation par SOAR.** Un playbook exécute l'enrichissement de l'IP, le blocage temporaire et le verrouillage du compte dès le déclenchement de l'alerte. Il supprime la part manuelle des délais de 10 à 11 minutes et réduit la fenêtre d'exposition en cas de Brute Force.
2. **SIEM en temps réel et enrichi.** Corréler les alertes par IP source, compte et hôte, ajouter la réputation de l'IP, et créer une liste de blocage partagée : comme 4 IP couvrent 83 cas, cette corrélation traite des campagnes et non des cas isolés.
3. **SLA différenciés et priorisation.** Définir un délai de triage par criticité et par type d'attaque, et router les incidents High vers une file dédiée. Aujourd'hui, le niveau de risque n'a aucun effet mesurable sur le délai.
4. **Contrôle de conformité et verrouillage de la clôture.** Interdire `Incident_Closed` sans `IP_Investigated`, et alerter la direction du SOC à chaque déviation. Associer chaque SLA de délai à un indicateur de conformité, puisque les raccourcis sont les cas les plus rapides.
5. **Organisation du SOC et supervision continue par Process Mining.** Attribuer un propriétaire de la file d'alertes, former les analystes au playbook, et rejouer chaque mois le journal sur le modèle de référence pour suivre la fitness et le taux de déviation.

6.4 Objectifs mesurables, KPI et SLA (Q1 complémentaire)

Objectif TO-BE	Indicateur	AS-IS	Cible
Réduire l'attente avant triage	MTTT (alerte → triage), incidents High	11,1 min	5 min ou moins
Supprimer les clôtures sans investigation	Part de cas sans `IP_Investigated`	9 sur 83 (10,8 %)	0 %
Réduire la durée de cycle des attaques	Durée moyenne de cycle, BruteForce	74,8 min	45 min ou moins
Supprimer les triages en double	Taux de re-triage	4 sur 83 (4,8 %)	moins de 2 %
Conformité au processus	Fitness sur les attaques	87,95 %	98 % ou plus

Ces cibles sont des objectifs de conception, pas des gains mesurés : elles seront validées sur un journal réel après la mise en œuvre.

6.5 Amélioration opérationnelle prioritaire (Q3 complémentaire)

Pour réduire le délai principal, l'action la plus rentable est d'automatiser le blocage temporaire de l'IP et le verrouillage du compte dès l'alerte, car cela supprime l'attente entre `SIEM_Alert_Created` et `SOC_Triage` du chemin critique de confinement. L'analyste conserve ensuite l'investigation et la décision, mais sur un incident déjà confiné.

7. Ouverture avancée : prédiction des dépassements de SLA par Machine Learning

Un modèle Random Forest atteint 83 % d'exactitude pour prédire qu'un incident dépassera 60 minutes, mais ce score est surtout un effet du type d'incident et ne justifie pas encore un usage en production.

7.1 Protocole

L'objectif est d'anticiper, dès la création du ticket, les incidents qui dépasseront le SLA de 60 minutes (`SLA_Breached = cycle_time_mins > 60`). Le modèle est un `RandomForestClassifier` (100 arbres, graine 42), entraîné sur `risk_level` , `department` et `scenario_label` encodés en variables binaires, avec un jeu de test de 30 % (42 cas).

7.2 Résultats

Classe	Précision	Rappel
SLA respecté	0,90	0,78
SLA dépassé	0,77	0,89

L'exactitude globale est de 83 %. Le rappel de 0,89 sur la classe « SLA dépassé » est le plus utile pour un SOC : il vaut mieux signaler à tort un incident que laisser passer un dépassement. Les variables les plus influentes sont `scenario_label = Benign` (41,8 %), puis `BruteForce` (14,5 %) et `CredentialStuffing` (7,9 %) : le type d'attaque est le principal facteur de délai.

7.3 Limites à lever avant tout usage

1. **Etiquette quasi confondue avec le type d'incident.** 63 des 83 attaques dépassent 60 minutes et aucun cas bénin ne le fait. Le modèle apprend surtout à distinguer une attaque d'un cas bénin.
2. **Fuite d'information.** `scenario_label` n'est pas connu à la création du ticket. En production, il faudrait le remplacer par le type de règle SIEM déclenchée.
3. **Petit échantillon.** 42 cas de test et aucune validation croisée : l'intervalle de confiance du score est large.

7.4 Perspectives

- Prédire le dépassement à partir de variables disponibles dès l'alerte (règle SIEM, réputation de l'IP, nombre de comptes ciblés, heure).
- Détecter par apprentissage non supervisé les traces rares (comme les variantes 4 et 5) avant qu'elles ne soient clôturées.
- Alimenter le routage du SOAR avec le score de risque de dépassement, pour envoyer en priorité les incidents à forte probabilité de retard.

- Surveiller le modèle dans le temps, car une dérive des attaques modifie la relation entre variables et délais.

8. Conclusion

Le SOC applique le processus de référence dans 87,95 % des incidents d'attaque (73 sur 83), mais il le fait sans priorisation, avec un délai de prise en charge de 11 minutes et en laissant passer neuf clôtures sans investigation de l'IP. Ce dernier point est le risque majeur : il empêche la corrélation entre incidents alors que 4 adresses IP seulement sont à l'origine des 83 attaques.

Trois enseignements guident la suite :

1. **Les raccourcis sont les cas les plus rapides.** Un indicateur de délai ne suffit donc pas ; chaque SLA doit être associé à un contrôle de conformité.
2. **Le niveau de risque ne pilote pas le traitement.** Les incidents High ne sont pas traités plus vite que les incidents Low.
3. **Le retard est structurel.** Il est de 10 à 11 minutes par transition quel que soit l'analyste, ce qui appelle une réponse d'automatisation et non de formation individuelle.

Le processus TO-BE proposé (SOAR, SIEM enrichi, SLA différenciés, clôture verrouillée, supervision par Process Mining) vise un triage à 5 minutes ou moins pour les incidents High et zéro clôture sans investigation. Ces cibles restent à valider sur un journal réel. La première étape recommandée à la direction est de verrouiller la clôture sans investigation de l'IP, une mesure sans coût technique élevé qui supprime immédiatement le risque principal.